信息安全测评与风险评估

4.2 网络设备配置核查

授课教师：张玉



目录

CONTENTS

01 案例导入：一条「允许所有」是怎么漏掉的

02 关键知识：四大维度与核查命令

03 动手实验：配置取证 + 判定

04 课内小结与下节预告

Part.01

案例导入——一条「允许所有」是怎么漏掉的

先看一场由配置疏漏引发的数据泄露，再明确你要练成的四项本事



案例导入：防火墙上那条「允许所有」，你能发现吗？

引入问题：防火墙策略中有一条“允许所有”，你能发现吗？

案例素材

某企业发生数据泄露事件，调查发现：攻击者通过互联网扫描发现了该企业防火墙的**22端口**对外开放，且使用了**默认口令**进行暴力破解成功。随后修改了防火墙策略，允许外部IP直接访问内部数据库，导致**30万条**客户信息被窃取。

事后审计发现的配置问题



素材1：案例导入
文字材料.docx

先想一想

1. 换你来查这份防火墙配置，你能找出几个问题？
2. 设备本身没被攻破，为什么数据还是泄露了？
3. 你觉得等保会要求查哪几项？先猜，再往下看

案例复盘

引入问题：防火墙策略中有一条“允许所有”，你能发现吗？

案例素材

某企业发生数据泄露事件，调查发现：攻击者通过互联网扫描发现了该企业防火墙的**22端口**对外开放，且使用了**默认口令**进行暴力破解成功。随后修改了防火墙策略，允许外部IP直接访问内部数据库，导致**30万条**客户信息被窃取。

事后审计发现的配置问题

素材1：案例导入文字材料.docx

有答案了吗？

1. 换你来查这份防火墙配置，你能找出几个问题？
2. 设备本身没被攻破，为什么数据还是泄露了？
3. 你觉得等保会要求查哪几项？

Part.02

关键知识——网络设备在等保里归哪一类

先搞清查什么、依据哪一条，再去翻配置



网络设备在等保测评中的定位

等保标准依据：GB/T 22239-2019

- **所属大类：** 安全技术要求 → 安全计算环境
- **测评对象：** 路由器、交换机、防火墙、堡垒机等
- **核心关注：** 设备自身的安全配置是否合规



为什么网络设备配置核查重要？网络设备是整个信息系统的“交通枢纽”：

路由器
决定数据包的转发路径，控制网络流量

交换机
连接网络节点，划分VLAN隔离区域

防火墙
网络安全的第一道防线，控制访问权限

堡垒机
运维管理的“安全入口”

一句话：如果网络设备配置不安全，整个系统的安全防线就形同虚设。网络的“交通警察”失守了，整个城市交通就乱套了。

Part.02 · 续

关键知识——四大维度怎么查

每个维度都按四步走：标准要求 → 核查命令 → 合格线 → 常见坑



网络设备配置核查——四大核心维度

对照GB/T 22239安全计算环境要求

维度	标准对应	核心检查内容	严重程度
身份鉴别	8.1.4.1	密码策略、登录限制、远程管理加密	
访问控制	8.1.4.2	账户权限、默认账户、最小权限	
安全审计	8.1.4.3	日志功能、审计记录保护	
入侵防范	8.1.4.4	服务端口、远程管理限制、漏洞修补	

维度一：身份鉴别（8.1.4.1）

- a 身份标识与鉴别：唯一标识，信息具复杂度且定期更换（二、三级）
- b 登录失败处理：限非法登录次数、连接超时自动退出等（二、三级）
- c 远程管理加密：采取必要措施防止鉴别信息被窃听（二、三级）
- d 双因素鉴别：两种及以上组合鉴别，至少使用密码技术（三级要求）

实操检查方法（核心指标对应）		
检查项	路由器（华为）	防火墙（华为）
密码复杂度	display password-policy	查看管理员密码策略
登录失败锁定	display login-block	查看登录失败锁定策略
超时退出	display user-interface	查看超时配置
远程管理加密	查看是否使用SSH而非Telnet	查看管理方式配置